

■ CAPTURE THE FLAG

Reto Académico de Ciberseguridad — Nivel Principiante

Categorías: Seguridad Web · Análisis de Redes

Objetivo	Desarrollar habilidades en identificación de vulnerabilidades web y análisis de tráfico de red mediante retos prácticos guiados.
Duración	90 – 120 minutos
Modalidad	Individual o en equipos de 2 personas
Herramientas	Navegador web, Wireshark, consola del navegador (DevTools)
Puntaje total	300 puntos (3 retos × 100 pts)

■ Instrucciones Generales

1. Cada reto presenta una situación simulada con contexto narrativo. Lee el escenario con atención.
2. La **flag** (bandera) siempre tiene el formato: `CTF{texto_aqui}`
3. Anota cada flag encontrada en la **Hoja de Respuestas** al final del documento.
4. No modifiques ni ataques sistemas reales. Todos los entornos son simulados o de laboratorio.
5. Está permitido consultar apuntes de clase, man pages y documentación oficial.
6. En caso de bloqueo, utiliza las **pistas** incluidas en cada reto (con penalización de puntos).

RETO 1 / 3 — Seguridad Web: SQL Injection

■ WEB — SQL Injection

■ 100 pts

■ Escenario

Eres analista de seguridad en una empresa de retail. El equipo de desarrollo lanzó recientemente un portal interno de consulta de inventario accesible en: <http://localhost:3000>. Sospechas que el formulario de autenticación no valida correctamente las entradas del usuario. Tu misión es confirmar la vulnerabilidad y extraer la flag oculta en la base de datos.

■ Objetivo

Bypasear el formulario de login utilizando una inyección SQL básica y obtener acceso al panel de administración donde se encuentra la flag.

■ Pasos Guiados

■ **Reconocimiento:** Abre el navegador y navega al formulario de login. Inspecciona el código fuente con **F12 → Elements**. Identifica los campos username y password.

■ **Prueba básica:** En el campo de usuario escribe una comilla simple: `'`. Presiona Enter. Observa si aparece un error de base de datos (esto confirma la vulnerabilidad).

■ **Payload de bypass:** Ingresa el siguiente payload en el campo usuario y cualquier texto en la contraseña:

```
' OR '1'='1' --
```

■ **Analiza la respuesta:** Si el login es exitoso, habrás bypassado la autenticación. Busca la flag en el panel que se muestra.

■ **Documenta:** Anota el payload utilizado y la flag obtenida.

■ Pistas

Pista 1: El operador OR en SQL evalúa condiciones en una consulta SELECT.

Pista 2: Los comentarios en SQL (-- o #) ignoran el resto de la consulta.

Pista 3: La consulta original es: `SELECT * FROM users WHERE user='X' AND pass='Y'`

■ Conceptos clave a investigar

- Inyección SQL (OWASP Top 10 – A03:2021)
- Prepared Statements / Consultas parametrizadas
- Principio de mínimo privilegio en bases de datos

RETO 2 / 3 — Seguridad Web: Cross-Site Scripting (XSS)

■ WEB — XSS Reflejado

■ 100 pts

■ Escenario

El mismo portal cuenta con una función de búsqueda de productos: `http://localhost:3000/buscar`. Observas que el término de búsqueda se refleja directamente en la respuesta HTML sin ningún tipo de sanitización. Un atacante podría inyectar código JavaScript malicioso que se ejecute en el navegador de otro usuario.

■ Objetivo

Demostrar la vulnerabilidad XSS reflejado inyectando un script que muestre un **alert()** en el navegador. Luego, encontrar la flag oculta en una cookie de sesión.

■ Pasos Guiados

■ **Verificar reflexión:** Escribe tu nombre en el buscador. Verifica con **Ctrl+U** que aparece en el HTML fuente.

■ **Inyección básica:** Reemplaza el término de búsqueda con el siguiente payload y observa si aparece un pop-up:

```
alert('XSS')
```

■ **Leer cookies:** Si el alert funcionó, usa este payload para leer la cookie de sesión (donde está la flag):

```
alert(document.cookie)
```

■ **Encuentra la flag:** La cookie contiene un valor codificado en Base64. Decodifícalo con: `echo 'VALOR' | base64 -d`

■ Pistas

Pista 1: El tag `<script>` permite ejecutar JavaScript en el contexto del navegador

. Pista 2: `document.cookie` contiene las cookies de la sesión actual.

Pista 3: Base64 no es cifrado; es solo una codificación. Usa CyberChef o el terminal.

■ Conceptos clave a investigar

- XSS Reflejado vs Almacenado vs DOM-based
- Content Security Policy (CSP)
- Sanitización y codificación de salidas (OWASP)

RETO 3 / 3 — Redes: Análisis de Tráfico con Wireshark

■ REDES — Análisis de Paquetes

■ 100 pts

■ Escenario

El equipo de respuesta a incidentes capturó tráfico de red sospechoso durante un ataque. Se te entrega el archivo `captura_sospechosa.pcap`. Un usuario transmitió credenciales y datos sensibles por un protocolo inseguro. Tu misión es analizar el archivo y recuperar la flag que fue transmitida en texto claro.

■ Objetivo

Utilizar Wireshark para filtrar y analizar el tráfico HTTP del archivo `.pcap`, identificar las credenciales expuestas y encontrar la flag transmitida en texto plano.

■ Pasos Guiados

- **Abrir el archivo:** Lanza Wireshark. Ve a **File** → **Open** y carga `captura_sospechosa.pcap`.
- **Filtrar HTTP:** En la barra de filtros escribe el siguiente filtro y presiona Enter:

`http`

- **Seguir el flujo:** Haz clic derecho en cualquier paquete HTTP → **Follow** → **HTTP Stream**. Lee el contenido completo.

- **Buscar credenciales:** Identifica campos POST con usuario y contraseña. Usa el buscador con:

`Ctrl+F` → escribe: `CTF{`

- **Localizar la flag:** La flag está en uno de los parámetros del cuerpo HTTP. Busca el patrón `CTF{`.

■ Pistas

Pista 1: HTTP transmite datos en texto plano. Prueba el filtro: `http.request.method == "POST"`

Pista 2: La función 'Follow HTTP Stream' reconstruye la conversación completa cliente-servidor.

Pista 3: Compara con tráfico HTTPS: en el `.pcap` verás que HTTPS cifra el cuerpo del mensaje.

■ Conceptos clave a investigar

- HTTP vs HTTPS — diferencias de seguridad
- Protocolo TLS/SSL — handshake y cifrado
- Sniffing de red y ataques man-in-the-middle (MitM)

■ HOJA DE RESPUESTAS — ENTREGA AL PROFESOR

Nombre del alumno / equipo	_____
Matrícula	_____
Fecha	_____

Reto	Categoría	Flag encontrada	Puntos	Obtenidos
Reto 1	SQL Injection	CTF{ _____ }	100	___ / 100
Reto 2	XSS Reflejado	CTF{ _____ }	100	___ / 100
Reto 3	Análisis de Red	CTF{ _____ }	100	___ / 100
			TOTAL	___ / 300

Preguntas de Reflexión (sin puntaje adicional)

1. ¿Qué medida implementarías para prevenir la vulnerabilidad SQL Injection encontrada?
2. ¿Por qué es peligroso transmitir datos sensibles por HTTP en lugar de HTTPS?
3. ¿Cómo afecta el XSS a los usuarios finales de una aplicación web?

■ Este documento es de uso exclusivo académico. Prohibida su distribución fuera del entorno educativo.